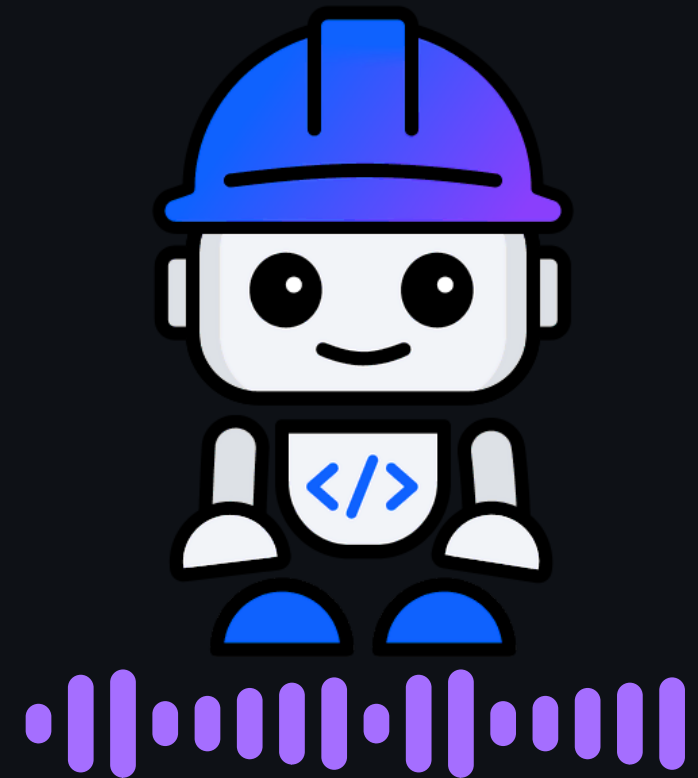


smartDesktop

explored, fixed and built by IBM Bob

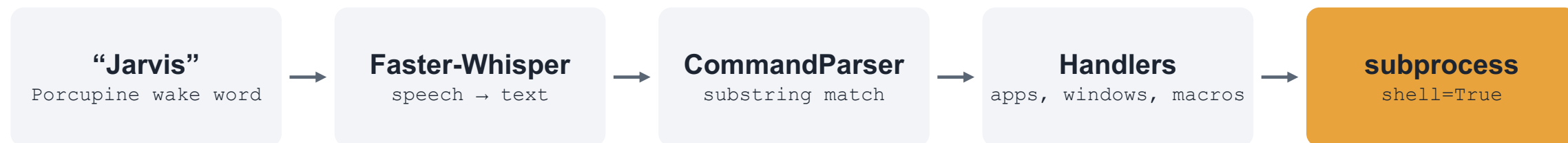
An offline voice assistant that turns speech into shell commands, and had never been audited.

→ smartdesktop-playground.onrender.com
github.com/Kelvin-Belmonte/smartDesktop



Team Kelvin-Belmonte

Speech goes straight to the shell



Anyone near the mic

Any voice can trigger a command, and a misheard phrase can still match a macro by substring (S-08).



Config and transcripts reach the shell

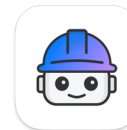
Unescaped AppleScript and cmd strings: two critical injections, S-01 and S-02.



No safety net

45 tests, one of which could never fail. One Ubuntu CI job. The README claims more OS support than the code has.

A playbook for Bob, not a single prompt



T1 · T9

SD Analyst

Documents the code:
architecture, command
catalog, OS matrix, after-
report.

edits only
docs/baseline/overview.md
docs/after/, README.md



T2

SD Auditor

Audits injection, unsafe
defaults and logging; runs
bandit and pip-audit.

edits only
docs/baseline/
security-audit.md



T3 · T8

SD Tester

Proves each bug with a
failing xfail(strict) test, then
builds the CI matrix.

edits only
tests/**
.github/workflows/ci.yml



T4 - T7

SD Developer

Fixes the bugs; builds dry-
run, text mode, playground
and the safety layer.

edits only
voice-assistant/**
playground/**

BOB_TASKS.md prompt



mode + fileRegex



Bob works



accept check passes



human reviews + commits

12 prompts · 436 Bob tool calls · ~11,000 lines of transcript in docs/bob-sessions/

What Bob found, and proved before fixing



7 functional bugs

- B-01 Macro steps sent to the shell as literal text
- B-02 Window commands hit an arbitrary window
- B-03 Linux terminal ignores installed emulators
- B-04 macOS apps with arguments fail to launch
- B-05 CPU fallback keeps the GPU float16 type
- B-06 Wake-word thread dies on any error
- B-07 Config silently overrides built-in commands

Each bug got a test marked `xfail(strict=True)` that failed until the fix landed.



9 security findings

2

Critical

3

High

4

Medium

S-01

AppleScript injection: unescaped string in do script "..."
(terminal.py:51)

S-02

cmd injection: shell=True with config and transcript values
(terminal.py:44)

bandit: 5 High, 12 Low · pip-audit: 0 CVEs, but nothing pinned

Before → after

Tests

45 → **163**

121 voice-assistant
+ 42 playground

CI jobs

1 → **8**

Ubuntu · macOS · Windows
× Python 3.10 / 3.12

bandit High

5 → **0**

no shell=True
anywhere

Open findings

16 → **0**

7 bugs + 9 security,
each traced to a test

`--text / --dry-run`

runs without a microphone

`confirm_destructive`

asks before closing or running

`PORCUPINE_ACCESS_KEY`

keeps the key out of config.yaml

What Bob built: try it without a microphone



```
$ printf 'start dev\n' |  
python main.py --text --dry-run
```

```
{"command": "start dev",  
  "action": "macro",  
  "platform": "macos",  
  "steps": [  
    {"action": "launch",  
      "target": "Terminal"},  
    {"action": "terminal",  
      "target": "npm run dev"}  
  ]  
}
```



Dry-run plans

CommandParser.plan() returns what would happen on Windows, macOS or Linux, without touching the machine.



Web playground

FastAPI and the Web Speech API, always dry-run. A test proves no process is ever spawned.



Safety layer

Confirmation for destructive commands, no shell=True, AppleScript via argv, redacted logs.

→ smartdesktop-playground.onrender.com

An honest record, and what's next



Where Bob was corrected

1

Logged planned actions instead of returning them.

A follow-up added `CommandParser.plan()`.

2

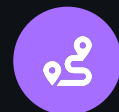
Rebuilt the playground and dropped 29 of 30 tests.

The guardrails caught it. Bob restored all 30 and added 12.

3

Missed an import that Python 3.14 hid.

CI on 3.10 / 3.12 caught it. Bob fixed it and ran pyflakes.



Next

- Window snapping on macOS and Linux (Windows-only today)
- Record and transcribe off the wake-word thread
- Confidence-scored matching instead of substring (S-08)
- Voice confirmation driven by the structured plan

→ smartdesktop-playground.onrender.com
Every Bob transcript: `docs/bob-sessions/`

